

PRIVILEGED & CONFIDENTIAL — ATTORNEY WORK PRODUCT — INTERNAL COMPLIANCE CHARTER Authoritative for AXIA program-level compliance posture. Referenced by Valley National Bank Questionnaire responses (I.14.i, I.21.ii, J.1, K.6, L.1–L.14) and by customer-facing contractual commitments (EULA v2, DPA Schedule A-US §13).

 **Not legal advice.** This output is a drafting and triage aid generated by a product-organization skill, not counsel. No attorney-client relationship is created by its production or use. Jurisdiction-specific questions, contested matters, and any decision with material legal or regulatory consequences require review by a licensed attorney in the relevant jurisdiction. Do not rely on this output as the sole basis for any legal, compliance, or employment decision.

Jurisdiction Assumed: U.S. federal + New Jersey (Valley National Bank supervisory context — primarily OCC for the national bank, with FDIC and state-banking overlays). AXIA entity: Delaware C-Corp. Non-U.S. jurisdictions (EU / UK / Israel) are out of scope for this Charter. If your jurisdiction differs, treat every provision below as a hypothesis to verify with local counsel.

Document: AXIA Compliance Program Charter v1.0 **Owner:** Guy Hindi, Chief Product Officer (authoritative owner; Qualified Individual under DPA Schedule A-US §13(a)) **Approver:** Asaf Massuri, Chief Executive Officer **Effective Date:** [TBD on signature] **Next Review:** [Effective Date + 12 months] or upon material change **Document Classification:** Internal / Releasable under NDA to prospective and existing customers **Version:** v1.0 — Initial minimum-viable charter (2026-04-22)

Architecture Context

"AXIA ships two components. The Gatekeeper and full system run locally under customer control with no egress. LLM-based severity judgment consumes an inference endpoint provisioned per engagement via one of three modes — cloud-infra-hosted (customer's contracted service), customer's internal LLM, or AXIA-provided (Llama 3.3 70B default, alternate open-weights swap path). The AI risk surface is resident with whichever party operates the endpoint."

This architectural lock (per Architecture Lock Memo v1.0 §D1–D2) shapes the compliance posture described below: AXIA's customer-data touchpoint is constrained to the Gatekeeper and full system running inside the customer environment, and Customer Data residency and oversight are properties of the customer's own environment rather than of AXIA-controlled infrastructure.

1. Purpose and Scope

The AXIA Compliance Program Charter defines AXIA Security, Inc.'s program-level posture for regulatory and contractual compliance. It governs the company's approach to customer-data handling, service-provider obligations (including FTC Safeguards Rule §314.4(f)), vendor oversight, incident response, and internal policy lifecycle. It is the anchor document referenced by AXIA's questionnaire responses, DPA commitments, and MSA representations.

The Charter covers AXIA's conduct as a service provider to regulated and non-regulated customers across the continental U.S. It does not create, extend, or redefine any regulatory obligation that attaches to AXIA's customers as the regulated entity of record; those obligations remain with the customer, and AXIA's program is designed to support — not substitute for — the customer's own compliance program.

2. Authoritative Owner

Guy Hindi, Chief Product Officer, is the authoritative owner of AXIA's Compliance Program. The CPO serves as the Qualified Individual under DPA Schedule A-US §13(a) (FTC Safeguards Rule 16 CFR §314.4(a) alignment) and is the single accountable person for the program's design, execution, and reporting.

All compliance-program questions — customer inquiries, regulator follow-ups, internal escalations, vendor-review escalations, and policy-review disputes — route through the CPO office. Day-to-day security engineering execution is led by the CTO and coordinated with the CPO; this division of labor is consistent across the Valley Questionnaire response (C.2.ii), DPA §13(a), and AXIA's EULA signatory structure.

The Chief Executive Officer (Asaf Massuri) is the program's executive approver. Material items affecting customer contracts, regulatory posture, or cross-function coordination escalate from the CPO to the CEO per §6 below.

3. Program Components

AXIA's Compliance Program consists of the following components as of the Effective Date. Each component is documented in a named artifact; the Charter does not restate policy content, it inventories the artifact set that the program comprises.

3.1 Policy Library

The policy library is maintained in `AXIA/Product/policies/` (internal) and `AXIA/Product/compliance/` (internal). The current library includes:

- **Information Security Policy & Standards** — AXIA's Written Information Security Program aligned to FTC Safeguards Rule §314.4 elements (see DPA Schedule A-US §13 for the element-

by-element mapping)

- **SDLC Policy v1.0** — secure software development lifecycle, change classes, and approval matrix
- **Configuration Management Plan v1.0** — configuration baselines, change control, and rotation cadence references
- **Incident Response SOP v1.0** — security incident classification, notification, and root-cause analysis; integrates with EULA §7.4 and DPA §7
- **Annual Penetration Test Plan v1.0** — scope, cadence, and third-party engagement planning for AXIA platform penetration testing
- **Bias Program Framing v1.0** — five-layer bias program (Govern / Measure / Manage / Validate / Human-Review Safety-Net) aligned to NIST AI RMF
- **Bias Audit Protocol v1.0 (draft)** — measurement protocols supporting the Bias Program Framing
- **Model Monitoring & Lifecycle SOP v1.0** — production-model monitoring, drift handling, and lifecycle gates
- **AI Supply Chain Posture v1.0** — foundation-model provider posture, inference-residency commitments, and customer-verification pathways
- **Training Data Inventory v1.0** — training-data provenance, classification, and use restrictions
- **NIST AI RMF Crosswalk v1.0** — mapping between AXIA controls and NIST AI RMF 1.0 / Generative AI Profile
- **Physical Security Program** — operational-site physical controls (Ramat Gan, Israel development site)
- **Business Continuity Plan (BCP)** — all-hazards continuity including pandemic-response content
- **Disaster Recovery Plan (DRP)** — recovery-oriented continuity for AXIA-operated systems
- **Corporate Incident Response Plan (CIRP)** — corporate-level incident handling complementing the platform-level Incident Response SOP
- **Incident Response Plan Highlights (IRP Highlights)** — companion artifact to the CIRP covering Advanced Persistent Threat (APT) handling and the development-vs-production (AWS dev-vs-prod) segmentation considerations that shape incident classification and containment at the platform layer

3.2 Vendor Oversight

Vendor oversight is executed through the **Vendor Risk Register v1.0** ([AXIA/Product/compliance/Vendor-Risk-Register-v1.0.md](#)). The Register inventories every vendor touching AXIA-operated systems, categorizes each by data-access scope and criticality, and tracks independent certifications and contractual flow-down status. Governance cadence: Vendor Risk Register — attestation by the Register owner on a periodic cadence; full review on the cadence aligned with the policy library's review cycle; material-change triggers documented in the Register itself.

3.3 Customer Contracts

AXIA's customer contractual framework carries the operational commitments that the Compliance Program supports:

- **EULA v2.0** with Schedules A–D (Data Processing Addendum, Deployment Architecture, Service Level Agreement, Order Form) — the master commercial and data-protection instrument
- **DPA Schedule A** (Israeli-law-oriented variant; Bank Discount baseline)
- **DPA Schedule A-US v1.0** (U.S.-law-oriented variant; for U.S. deployments including Valley) — carries the §13 Qualified Individual designation, the §6.4.2 service-provider oversight commitment, and the §7.2 stricter-of-applicable-baselines notification stack

Customer contracts and the Compliance Program are intentionally coupled: contractual anchors (EULA §7.4 notification, DPA §9 retention, DPA §13 WISP elements, DPA Schedule A-US §6.4.3 OCC/SR 23-4 alignment) are the pointer set that questionnaire responses and regulatory inquiries resolve against.

3.4 Third-Party Compliance Engagement

AXIA has engaged **Scytale** to lead a formal SOC 2 Type 2 readiness program. The engagement is in flight; completion timing depends on scope definition, readiness-assessment outcome, and external-auditor availability, and is not committed to a fixed date under this Charter. AXIA will make the completed SOC 2 Type 2 report available to customers under customary confidentiality protections once it is issued. Pending completion, AXIA supports customer third-party risk management through the artifact set in §3.1, the Vendor Risk Register in §3.2, and customer-specific evidence requests on a reasonable-efforts basis.

4. Program Cadence

The program's operational cadence is as follows. Cadence statements describe current practice; where a cadence is being established, this Charter discloses the honest current state (see §7 Roadmap).

- **Program attestation and review.** Attestation by the Qualified Individual on a periodic cadence. Full program review at a cadence aligned with the policy library's review cycle, with material-change triggers documented in the Vendor Risk Register.
- **Penetration testing.** Per Annual Penetration Test Plan v1.0. Initial third-party penetration test is scheduled under that plan; ongoing cadence stabilizes post-SOC 2 Type 2.
- **Incident response.** Per Incident Response SOP v1.0 and EULA v2 §7.4 notification commitments. DPA Schedule A-US §7.2 sets the stricter-of-applicable-baselines stack for regulated-FI customers (two-hour provisional notification to Customer as the operational baseline).
- **Senior-management review.** Senior-officer reporting from the CPO (as Qualified Individual per DPA Schedule A-US §13(i)) to the CEO and to the AXIA board is contemplated under this Charter

on a periodic cadence; the formal attestation cadence is being established and stabilizes post-SOC 2 Type 2. Interim reporting runs on exception (material incident, material change in the control environment, material regulatory development).

5. Compliance Scope — Regulatory Framework Alignment

AXIA's Compliance Program is designed with reference to the following regulatory frameworks, in the capacity stated. Citations are descriptive of the design target that informs AXIA's posture as a service provider; they are not claims of independent statutory obligation or conformance certification except where AXIA holds a specific attestation.

5.1 FTC Safeguards Rule (16 CFR §314.4)

"AXIA complies with the FTC Safeguards Rule at 16 CFR §314.4 as a service provider processing NPI, including the administrative, technical, and physical safeguards specified therein. Our contractual framework, compensating controls, and access-management posture address §314.4(f) service-provider oversight requirements. We do not make consumer credit decisions and are not a financial institution for GLBA privacy-notice purposes under 16 CFR Part 313."

The element-by-element mapping of AXIA's Written Information Security Program to §314.4(a) through §314.4(i) is carried in DPA Schedule A-US §13 (Qualified Individual, Risk Assessment, Safeguards, Regular Testing, Training, Service-Provider Oversight, Change Management, Written Incident Response Plan, Senior-Officer Reporting). This Charter incorporates that mapping by reference.

5.2 GLBA (16 CFR Part 313 — Privacy Rule)

AXIA does not make consumer credit decisions and is not a financial institution for GLBA privacy-notice purposes under 16 CFR Part 313. Privacy-notice obligations attach to AXIA's customer (the regulated financial institution); AXIA supports the customer's program through the service-provider posture described in §5.1.

5.3 NIST AI Risk Management Framework 1.0

AXIA's AI posture is mapped to NIST AI RMF 1.0 and the Generative AI Profile via **NIST-AI-RMF-Crosswalk-v1.0.md**. The Crosswalk is the authoritative mapping between AXIA controls (Bias Program Framing, Model Monitoring SOP, AI Supply Chain Posture, Training Data Inventory) and the four NIST AI RMF core functions (Govern, Map, Measure, Manage). NIST AI RMF is a framework, not a regulatory statute; AXIA is "designed with reference to" rather than "certified against."

5.4 SOC 2

SOC 2 Type 2 readiness is in progress via Scytale (see §3.4). Pending completion, AXIA does not claim a SOC 2 Type 2 attestation. Upon issuance, the attestation is made available to customers under NDA.

5.5 Other Frameworks (Conditional / Customer-Specific)

Additional frameworks become part of AXIA's compliance scope on a per-customer basis when the customer's supervisory perimeter triggers them. Examples: NYDFS 23 NYCRR Part 500 for Covered Entities; SEC Reg S-P §248.30 for registered broker-dealers / investment advisers / investment companies; federal interagency 36-hour banking incident notification (12 CFR Parts 53 / 225 / 304) for federally supervised banks; applicable state breach-notification statutes (e.g., N.J.S.A. 56:8-163 for New Jersey residents). These conditional framework applicabilities are resolved at MSA execution per DPA Schedule A-US §1 and §7.2.

6. Escalation and Accountability

Compliance issues escalate through a single spine. The primary ownership chain is:

- **Day-to-day compliance execution** — Security Architect (Vendor Risk Register ownership, sub-processor notice issuance, cadence tracking) with oversight from the CPO.
- **Program-level authority** — Guy Hindi, Chief Product Officer (as authoritative owner and Qualified Individual per DPA Schedule A-US §13(a)).
- **Material items affecting customer contracts or regulatory posture** — Asaf Massuri, Chief Executive Officer, on escalation from the CPO.
- **Customer-notification obligations** — flow through the Incident Response SOP per EULA §7.4 commitments and DPA Schedule A-US §7.2 stricter-of-applicable-baselines stack; the CPO is the single point of contact for incident coordination with the customer.

Material items that require both CPO and CEO sign-off include: material changes to the customer-contractual framework (EULA / DPA amendments); adoption of new regulatory frameworks into the compliance scope; material incident disclosures to regulated-FI customers; and any commitment to a named third-party attestation with a specific completion date.

7. Roadmap (Tier 3 — direction only)

The following items are honest gap disclosures, not commitments to specific dates. They reflect the current early-stage maturity of AXIA's compliance program and will progress as the company scales and as customer engagements surface specific maturity requirements.

- **SOC 2 Type 2 certification completion.** Scytale-led readiness program is in flight (§3.4); completion timing is subject to scope, readiness assessment, and external-auditor availability.

- **Formal annual senior-management compliance attestation cadence.** Annual reporting from CPO to CEO and board is contemplated under §4; the formal attestation-document cadence stabilizes post-SOC 2 Type 2.
- **Named Security Architect role.** Security Architecture responsibilities are currently owned by the CPO. A dedicated Security Architect role is on the 2026 hiring roadmap; the named individual will assume Vendor Risk Register ownership and sub-processor governance execution from the CPO when hired.
- **Formal third-party contractor screening program.** Current posture is reference verification (prior employment and education) and contractual representations regarding background. Formal third-party screening (criminal, credit, drug, where lawful) is on the 2026 program-maturation roadmap.
- **Formal security-awareness training program.** Informal security guidance is currently provided during employee onboarding and at periodic team meetings (per DPA Schedule A-US §13(e)). Formalization of curriculum, cadence, and completion tracking will occur in coordination with SOC 2 Type 2 readiness work.

Reviewer Checklist

Before this Charter is adopted as the authoritative program artifact and referenced in customer-facing responses (Valley Phase 10 Excel and downstream), the following binary sign-off items must be addressed by Asaf Massuri (CEO) and Guy Hindi (CPO):

- [] Authoritative-owner attribution (Guy Hindi, CPO) in §2 is accurate and accepted, including the dual role as Qualified Individual under DPA Schedule A-US §13(a)
 - [] All policy docs named in §3.1 exist at the paths referenced in `AXIA/Product/policies/` and `AXIA/Product/compliance/`
 - [] Program cadence statements in §4 reflect current reality, not aspiration (in particular: quarterly vendor attestation, annual vendor full review, annual policy review, annual penetration testing, annual senior-management review contemplated post-SOC 2)
 - [] Regulatory alignment in §5 is accepted as the authoritative framing for Valley and future U.S. customers; §5.1 §314.4(f) paragraph is accepted verbatim
 - [] Roadmap items in §7 are honest gap disclosures, not commitments to specific dates; the Security Architect 2026 hiring note, training program formalization, and contractor-screening roadmap are accurate to current planning
 - [] Cross-reference consistency confirmed: authoritative-owner attribution matches B.4.i, C.2.ii (per Asaf confirmation 2026-04-22), DPA Schedule A-US §13(a), EULA signatory structure, and Physical Security Program signatory
 - [] Scytale engagement framing in §3.4 and §7 is accurate (no completion-date commitment; report available under NDA when issued)
-

Cannot Assess Without

The following items are outside the scope of this Charter and require licensed counsel or other named expertise before this Charter is incorporated into customer-facing commitments:

- **Licensed counsel review of §5 regulatory alignment** before submission of the Charter to any regulated customer. The §5.1 §314.4(f) paragraph is drafted with General Counsel consultation (per the Specificity Ladder v1.0 Review Integration) but licensed U.S. counsel validates the framing on the final Valley-submission artifact on a per-deal basis.
- **SOC 2 Type 2 scope and auditor-selection confirmation from Scytale** before §3.4 is referenced as an active attestation engagement in any customer-facing response. Pending that confirmation, §3.4 is accurate to the current "readiness program in flight" state but does not commit to a specific auditor, scope, or completion date.
- **MSA R&W gate status** (DPA Schedule A-US Finding 4; Architecture Lock Memo D5) before this Charter is incorporated into customer-facing commitments. If a given customer's MSA incorporates questionnaire responses by reference as representations and warranties, every cadence statement in §4 and every roadmap disclosure in §7 must be re-audited through an MSA-warranty lens before submission.
- **NYDFS Part 500 and SEC Reg S-P applicability per customer** before §5.5 conditional frameworks become part of the named compliance scope for a specific engagement. Customer corporate structure and supervisory perimeter are the resolving facts; Charter framing is deliberately conditional pending that resolution.
- **Operational readiness of the Security Architect role transition** — the Charter describes the current CPO-owned posture and the 2026 hiring roadmap. Whether Vendor Risk Register execution capacity at current AXIA headcount is sustainable through the hiring transition is a CPO and CEO determination that the Charter does not resolve.

Sign-off lines (to be completed on acceptance):

- Guy Hindi (CPO — authoritative owner): _____ Date: _____
- Asaf Massuri (CEO — executive approver): _____ Date: _____

Document	ID:	DOC-2026-AXIA-COMPLIANCE-CHARTER-v1.0	Cross-references:
AXIA/Product/policies/Architecture-Lock-Memo-v1.0.md		§D1–D3;	
AXIA/Product/compliance/Vendor-Risk-Register-v1.0.md		§1–9; AXIA/Product/compliance/VNB-Specificity-Ladder-GLBA-L12-v1.0.md	
Finding	3;	AXIA/Valley-Bank-Submission/Contract-Stage/DPA-Schedule-A-US-v1.0.md	
§6, §7, §13;		AXIA/Marketing/Collaterals/AXIA-Enterprise-License-Agreement-v2.docx	
§7.4.			

This Charter describes AXIA's internal compliance program. It is informational and is not intended as a contractual representation. Binding commitments are captured in AXIA's Enterprise License

Agreement and Data Processing Addendum, provided at contract stage.

AXIA Security · Confidential · Available on Request · AXIA Compliance Program Charter v1.0